1. Цель

Организация непрерывного сбора, анализа и хранения событий безопасности, позволяющая своевременно выявлять инциденты, расследовать их и оценивать эффективность средств защиты.

2. Объекты мониторинга

- Операционные системы серверов и АРМ (Astra Linux Special Edition);
- СУБД (журналы доступа, изменения данных);
- ИИ-модуль (обращения к модели, предсказания, ошибки);
- Прикладное ПО тренажёра (действия пользователей, запуск сценариев);
- Сетевое оборудование (NGFW, VPN, IDS/IPS);
- СЗИ (антивирус, DLP).

3. Технические средства

Используется SIEM MaxPatrol (или RuSIEM) с агентами на всех защищаемых узлах. Журналы передаются по защищённому каналу (TLS 1.3) и хранятся в централизованном хранилище с резервированием.

4. Типовые корреляционные правила

- Несколько неудачных входов от одного IP – брутфорс.
- Вход в систему в нерабочее время (с 22:00 до 06:00) – аномалия, требующая проверки.
- Массовое скачивание отчётов или моделей – возможная утечка.
- Изменение эталонных сценариев или конфигураций без оформленной заявки – саботаж.
- Резкое изменение весов модели – попытка отравления.

5. Профили нормального поведения (UEBA)

На основе истории действий для каждого пользователя строится поведенческий профиль. Отклонения (например, редкий вход, работа с необычными сценариями) генерируют предупреждения.

6. Хранение логов

- Срок хранения – не менее 1 года для журналов безопасности, не менее 3 лет для журналов доступа к персональным данным.
- Ежедневно делается резервная копия логов.

7. Реагирование на события

Все события с уровнем риска выше среднего передаются в панель оператора и автоматически создают инцидент в системе управления ИБ. Оператор SIEM в рабочее время обязан подтвердить приём алерта в течение 15 минут.

8. Аудиторские проверки

Не реже 1 раза в квартал аудитор проводит выборочную проверку полноты и корректности логирования, результаты оформляются актом.